



STANDARDS AND REGULATIONS

AN INTRODUCTION TO ISO27001, FFIEC & GDPR



Version: 1.1a
Date: 29/03/2018
Author: Sylvain Martinez
Reference: ESC3-MUSCL
Classification: Public

CONTENTS

CONTEXT

- Why Care?
- Goals.

ISO 27001

- ISO 27001 Purpose;
- ISO 27002 Purpose;
- ISO 27001 Vs 27002;
- ISO 27001 Domains;
- ISO 27002 Domains.

FFIEC

- FFIEC Purpose;
- FFIEC Overview;
- Maturity Assessment Statistics;
- Maturity Domains;
- ISO 27001 Vs FFIEC.

GDPR

- GDPR Key Facts;
- MAURITUS DPA 2017;
- FREE Resources.

WHY CARE?



**HEAVY
FINES**



**BUSINESS
ENABLEMENT**

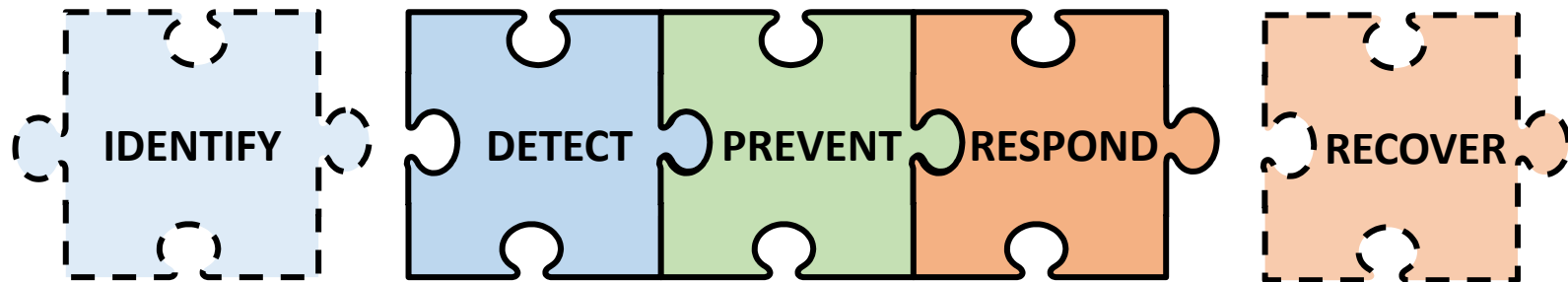


**ENHANCED
SECURITY**

DIFFERENT FRAMEWORKS AND STANDARDS



SAME GOALS



27001

Information security management systems Requirements

- Helps organizations to keep secure both their information assets and those of their customers.
- It provides requirements for establishing, implementing, maintaining and continually improving an information security management system.
- It can be used by internal and external parties to assess the ability of an organization to meet its own information security requirements.

27002

Code of Practice for Information Security Controls

- Helps organizations to keep secure both their information assets and those of their customers.
- It offers organizations a wide selection of security controls, together with accompanying implementation guidance.

ISO 27001 vs. 27002

ISO 27001

- You **can** get certified;
- Management Standards;
- Information Security must be planned, implemented, monitored, reviewed and improved;
- Defines management responsibilities;
- **High Level.**

ISO 27002

- You can **not** get certified;
- Comprehensive set of controls;
- Full list of controls may not apply to all organizations.
- **Very detailed.**

ISO 27001 DOMAINS

7x ISO 27001 DOMAINS

Context of the Organization

Leadership
(policy, roles,
responsibilities, etc.)

Planning
(Action to address risks,
security objectives)

Support
(Resources, competence,
awareness, etc.)

Operation
(Planning and control, risk
assessment, etc.)

Performance evaluation
(monitoring, measurement,
internal audit, etc.)

Improvement
(corrective action,
continual improvement)

ISO 27002 DOMAINS

14x
ISO 27002
DOMAINS

**Information Security
Policies**

**Organization of Information
Security**

Human Resource Security

Asset Management

Access Control

Cryptography

**Physical and Environmental
security**

Operations Security

Communication Security

**System acquisition, development
and maintenance**

Supplier relationships

**Information security
incident management**

**Information security aspects of
business continuity management**

Compliance

FFIEC

Cybersecurity Assessment Tool (version 2.1, August 2017)

- **Assesses the complexity of an institution's operating environment**, including the types of communication connections and payments initiated, as well as how the institution manages its information technology products and services. **(Inherent Risk)**
- **Assesses an institution's** current practices and **overall cybersecurity** preparedness. **(Maturity)**
- **Helps make risk-informed decisions** to identify and **prioritize actions** to enhance the effectiveness of **cybersecurity-related programs** and the overall level of **preparedness** to address the **increasing cybersecurity threats**.

		Inherent Risk Levels				
		Least	Minimal	Moderate	Significant	Most
Cybersecurity Maturity Level for Each Domain	Innovative					
	Advanced					
	Intermediate					
	Evolving					
	Baseline					

MATURITY ASSESSMENT STATISTICS

8x DOMAINS

15x ASSESSMENTS FACTOR

30x COMPONENTS

494x QUESTIONS

BASELINE
(123)

EVOLVING
(113)

INTERMEDIATE
(113)

ADVANCED
(86)

INOVATIVE
(59)

MATURITY DOMAINS

CYBER RISK MANAGEMENT AND OVERSIGHT

THREAT INTELLIGENCE AND COLLABORATION

CYBERSECURITY CONTROLS

EXTERNAL DEPENDENCY MANAGEMENT

CYBER INCIDENT MANAGEMENT AND RESILIENCE

ISO 27001 vs. FFIEC

ISO 27001

- You **can** get certified;
- Management Standards;
- YOU choose what ISO 27002 controls apply to your company;
- **Internationally recognised**

FFIEC

- You can **not** get certified;
- Includes and starts with a risk context assessment;
- Guided approach as to which controls applies to you;
- Very comprehensive list of requirements and recommendations;
- **Mainly USA usage with an uptake in Africa.**

GDPR KEY FACTS



25TH OF MAY 2018



ALL COMPANIES



4% OR €20 MILLION



72H REPORTING



RIGHT TO ACCESS



PRIVACY BY DESIGN AND BY DEFAULT



RIGHT TO BE FORGOTTEN

MAURITIUS DPA 2017



INTRODUCED IN DECEMBER 2017



PASSED ON 22/12/2017 – ACT 20



REPLACES THE DPA 2004



ALIGNED WITH GDPR



SMALLER FINE



ICO – Interactive Online Assessment Tool

<https://ico.org.uk/for-organisations/guide-to-the-general-data-protection-regulation-gdpr/>



CNIL – French guide on GDPR (case studies)

<https://www.cnil.fr/fr/nouveautes-sur-le-pia-guides-outil-piaf-etude-de-cas>



CNIL – Privacy Impact Assessment software

<https://www.cnil.fr/fr/outil-pia-telechargez-et-installez-le-logiciel-de-la-cnil>

ABOUT ELYSIUMSECURITY LTD.

ElysiumSecurity provides a portfolio of **Strategic** and **Tactical Services** to help companies protect and respond against Cyber Security Threats. We differentiate ourselves by offering discreet, tailored and specialized engagements.

Operating in **Mauritius** and in the **United Kingdom**, our *boutique style* approach means we can easily adapt to your business operational model and requirements to provide a personalized service that fits your working environment.

ElysiumSecurity provides **high level expertise** gathered through years of **best practices experience** in large international companies allowing us to provide advice best suited to your **business operational model** and **priorities**.

ElysiumSecurity provides **practical expertise** to **identify vulnerabilities**, assess their **risks** and **impact**, **remediate** those risks, **prepare** and **respond** to incidents as well as raise **security awareness** through an organization.

